

Security+ 1.4 · Key Exchange

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Key Exchange (3:39)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Diffie-Hellman: duas partes derivam a MESMA chave secreta trocando só valores PÚBLICOS — sem enviar a chave! Na TLS moderna usa-se ECDHE (efêmero): chave NOVA a cada sessão, dando Perfect Forward Secrecy (se a chave privada vazar amanhã, sessões passadas não decifram).

💡 Highlights que a prova cobra

- DH troca valores públicos e deriva chave privada — a chave NUNCA viaja
- Ephemeral (ECDHE) = chave por sessão — PFS
- PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas

🎯 Dicas de prova & Cenários Típicos

- 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman
- 'protects past sessions even if key leaks' = Perfect Forward Secrecy

Cenário clássico de exame: Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Key Exchange) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Trocar uma chave secreta por canal público SEM enviá-la diretamente usa:

- A)** Diffie-Hellman
- B)** AES
- C)** SHA-256
- D)** Base64

2. Qual tipo de criptografia usa pares de chaves pública e privada?

- A)** Hashing
- B)** Criptografia simétrica
- C)** Criptografia assimétrica
- D)** Steganografia

3. AES é um exemplo de criptografia:

- A)** Simétrica (mesma chave cifra e decifra)
- B)** Assimétrica (par de chaves)
- C)** Hash de mão única
- D)** Codificação Base64

4. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'DH troca valores públicos e deriva chave privada — a chave NUNCA viaja'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja...

5. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Ephemeral (ECDHE) = chave por sessão — PFS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Ephemeral (ECDHE) = chave por sessão — PFS...

6. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas...

7. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'requires parties to derive a shared secret over untrusted channel' = Diffi...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'protects past sessions even if key leaks' = Perfect Forward Secrecy'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'protects past sessions even if key leaks' = Perfect Forward Secrecy...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' →...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Key Exchange): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'DH troca valores públicos e deriva chave privada — a chave NUNCA viaja'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — Diffie-Hellman.

✓ **Por que está certa:** Diffie-Hellman deixa duas partes derivarem a MESMA chave secreta trocando só valores públicos. Base da troca de chave do TLS.

✗ **Por que as outras estão erradas:**

- **AES:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **SHA-256:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **Base64:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — Criptografia assimétrica.

✓ **Por que está certa:** Criptografia assimétrica (como RSA, ECC) usa par de chaves matematicamente relacionadas: pública para criptografar e privada para descriptografar, ou vice-versa para assinatura.

✗ **Por que as outras estão erradas:**

- **Hashing:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **Criptografia simétrica:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **Steganografia:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) A — Simétrica (mesma chave cifra e decifra).

✓ **Por que está certa:** AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação.

✗ **Por que as outras estão erradas:**

- **Assimétrica (par de chaves):** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **Hash de mão única:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- **Codificação Base64:** Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) D — Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): DH troca valores públicos e deriva chave privada — a chave NUNCA viaja.

✗ **Por que as outras estão erradas:**

- **Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:** Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- **Substituir controles técnicos preventivos por termos de adesão informais:** Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: Ephemeral (ECDHE) = chave por sessão — PFS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): Ephemeral (ECDHE) = chave por sessão — PFS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'requires parties to derive a shared secret over untrusted channel' = Diffie....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'protects past sessions even if key leaks' = Perfect Forward Secrecy....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): 'protects past sessions even if key leaks' = Perfect Forward Secrecy.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' →....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): Cenário típico: 'dois sistemas estabelecem criptografia sem trocar chave' → Diffie-Hellman..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: DH troca valores públicos e deriva chave privada — a chave NUNCA viaja....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Key Exchange): DH troca valores públicos e deriva chave privada — a chave NUNCA viaja.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.